SECURITY

Zero Trust Architecture

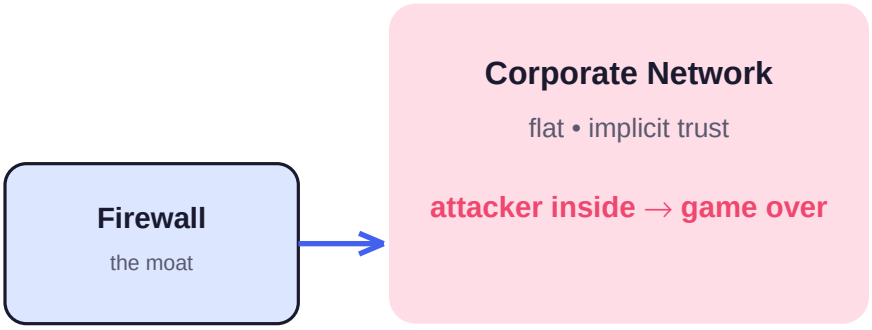
Never trust, always verify.
Security for a world without perimeters.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

The Old Model: Castle and Moat

Hard shell, soft center — once inside, attackers roam free.



VPNs extend the moat to homes and cafes — but the inside is still implicitly trusted. Lateral movement is trivial.

STEP 2/6

The Zero Trust Principle

No implicit trust — not for users, devices, networks, or workloads.

Verify explicitly

Authenticate + authorize every request: identity, device health, context.

Least privilege

Just-in-time, just-enough access. No standing admin.

Assume breach

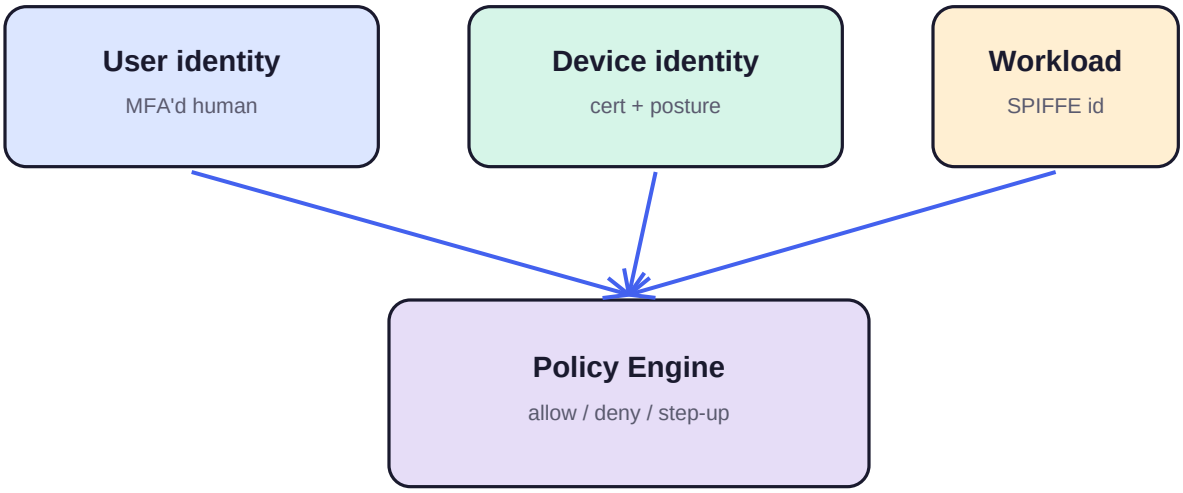
Segment so a compromise stays contained; monitor everything.

"The network is always hostile — even your own."

STEP 3/6

Identity Becomes the Perimeter

Every request carries proof of who/what is asking.

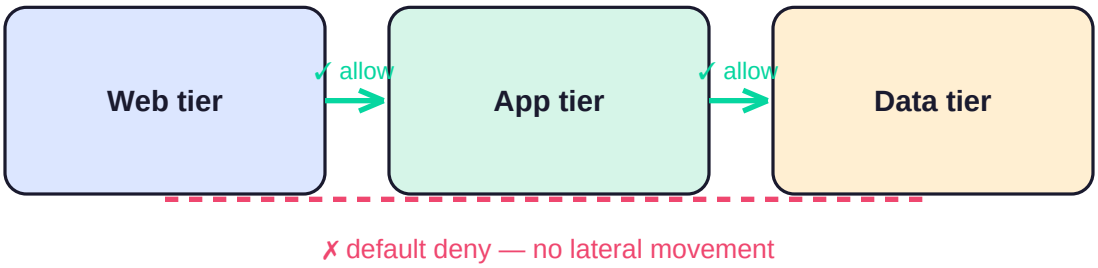


Signals: who, what device, where, when, risk score → decision per request.

STEP 4/6

Micro-Segmentation

Shrink the blast radius: tiny zones, explicit allow-rules between them.



East-west traffic (server to server) gets the same scrutiny as north-south. Compromising web doesn't reach data.

STEP 5/6

The Pillars of Zero Trust

Six areas to harden — maturity is a journey.

Identities

Phishing-resistant MFA, passwordless where possible

Devices

Managed, patched, encrypted, attested health

Networks

Encrypted, segmented, no implicit trust zones

Applications

Secure SDLC, runtime protection

Data

Classify, encrypt, DLP, minimal retention

Visibility

Centralized logs, UEBA, automated response

STEP 6/6

Putting It Together: A Request's Journey

One API call, verified five ways.

1. User + device authenticate (MFA, cert)
2. Policy engine evaluates risk signals
3. Micro-segment allows web→app only
4. Service identity (mTLS) app→data
5. Everything logged to SIEM

STEP ✓I✓

Key Takeaways

Zero Trust — Remember

- Verify explicitly, least privilege, assume breach — the three tenets.
- Identity (user + device + workload) replaces the network perimeter.
- Micro-segmentation with default-deny contains lateral movement.
- Harden all six pillars: identities, devices, networks, apps, data, visibility.
- Every request is authenticated, authorized, encrypted, and logged.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev